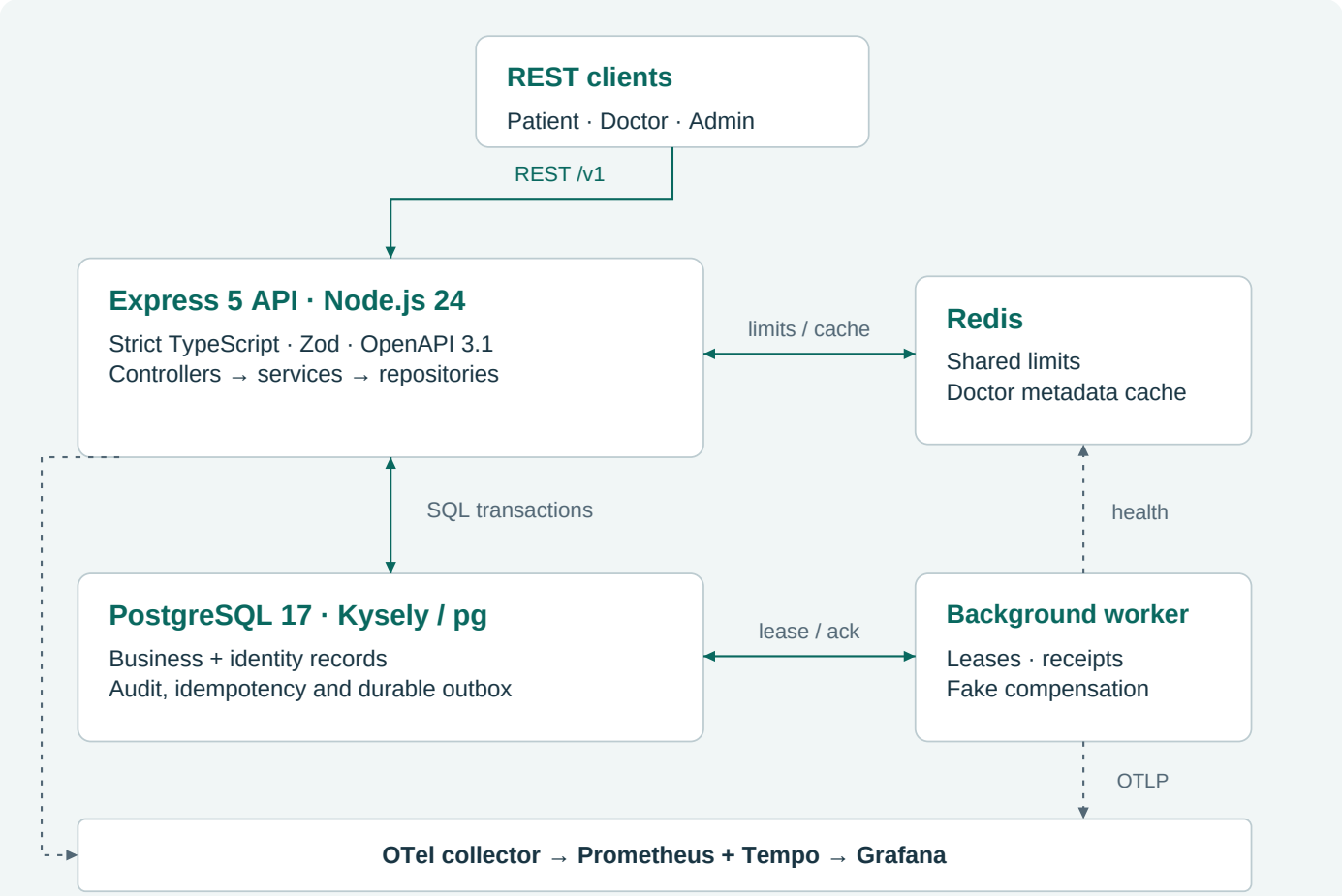
System architecture

A modular REST backend: one codebase, separate API and worker processes, PostgreSQL as the source of truth.

IMPLEMENTED & LOCALLY VERIFIED

Solid: application/data flow · Dashed: telemetry or dependency



AWS MAPPING · DEFINED IN TERRAFORM, NOT DEPLOYED

HTTPS ALB → private ECS Fargate API / worker; RDS PostgreSQL Multi-AZ; replicated Valkey-compatible cache. Private ECR/endpoints, IAM, KMS and secret references; ADOT → X-Ray / CloudWatch. No AWS deployment or paid provisioning is claimed.

Modules and ownership

Identity and MFA; owned availability and discovery; booking/cancellation; clinical notes and prescriptions; internal payments, audit and admin analytics. Constructor injection and an explicit composition root bind ports to infrastructure; transaction-scoped repositories share one SQL connection. Operator-only bootstrap is locked out after the first admin.

API and clinical boundaries

37 OpenAPI paths cover the implemented surface. Consultation states: scheduled → in_progress → completed; scheduled → cancelled / no_show. Assigned doctors author notes and prescriptions; patients see only their own finalized prescriptions. Admin analytics use bounded date ranges and an asOf timestamp.

Local Compose uses development DB/Redis connections; production requires verified PostgreSQL and Redis TLS. Forwarded addresses are untrusted unless ingress CIDRs are explicit. No frontend, video calling or real payment gateway.

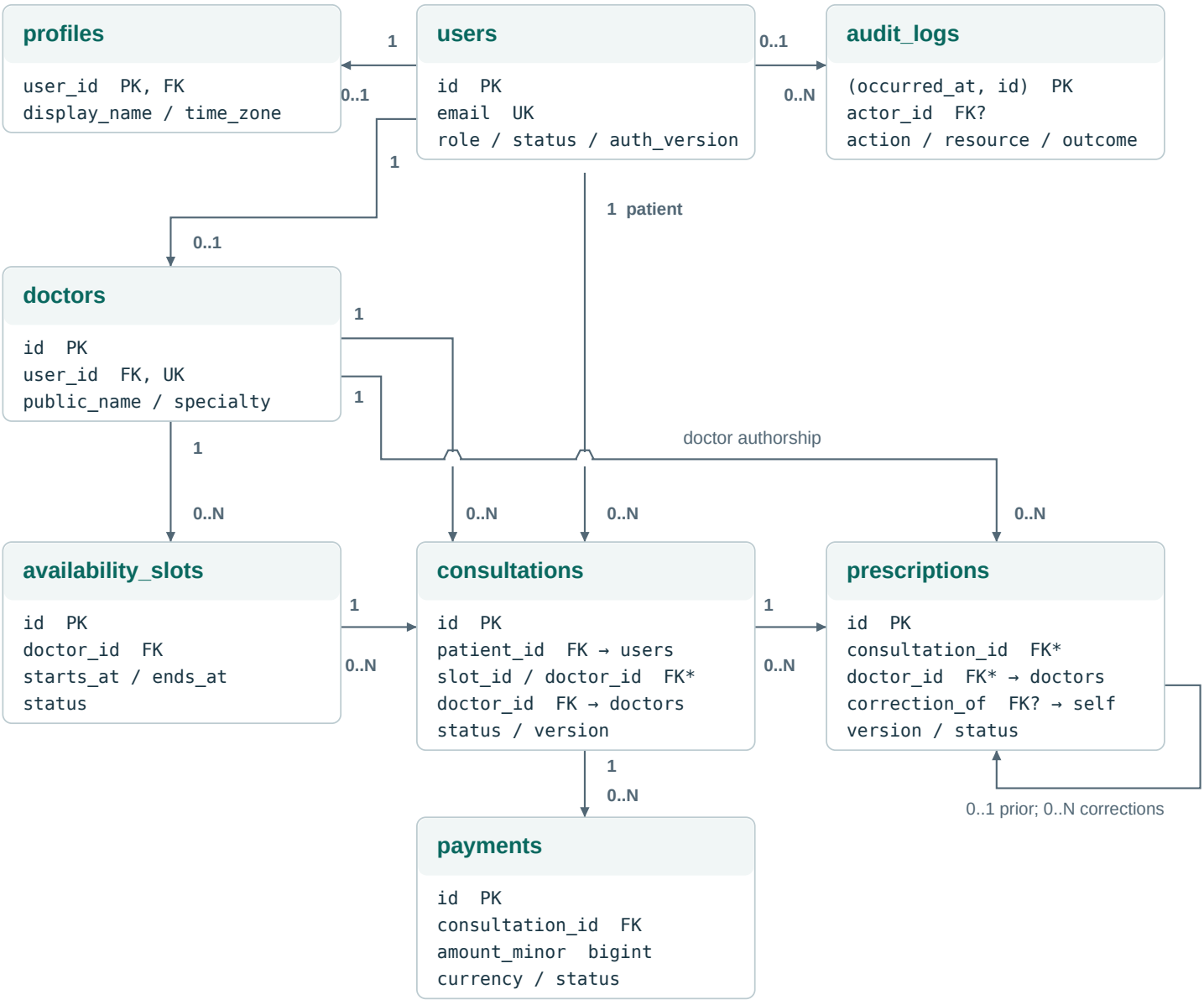
Sources: composition-root.ts; compose*.yaml; infra/terraform/; docs/openapi.json

Data model & integrity

Eight core tables and ten supporting tables. Physical keys and relationships follow SQL migrations 0001–0009.

CORE ER DIAGRAM

PK primary · FK foreign · UK unique · ? nullable



*** Composite FKs:** consultations(slot_id, doctor_id) → availability_slots(id, doctor_id); prescriptions(consultation_id, doctor_id) → consultations(id, doctor_id). Core IDs: UUID; time: timestamptz. Audit partitions use occurred_at.

SUPPORTING KEYS & RELATIONSHIPS

auth_sessions
PK id · FK user_id → users

refresh_token_history
PK token_hash · FK session_id → auth_sessions

auth_flows
PK id · FK user_id → users

mfa_factors
PK id · UK/FK user_id → users; composite FK (enrollment_flow_id, user_id) → auth_flows

mfa_recovery_codes
PK id · FK user_id → users

auth_tokens
PK id · FK user_id → users

idempotency_records
PK id · FK actor_id? → users · UK (scope, key)

outbox_jobs
PK id · UK deduplication_key · optional trace_parent

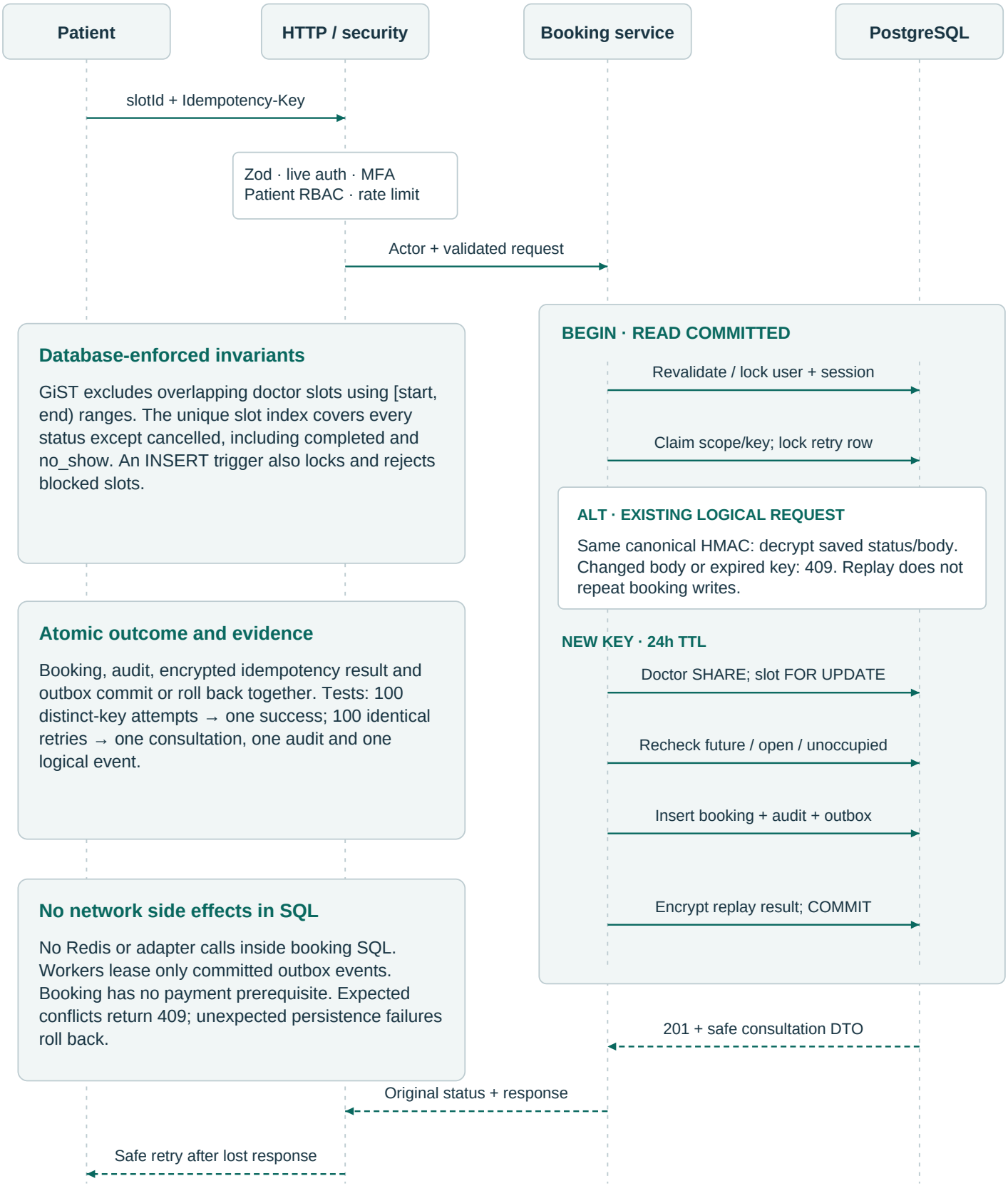
job_receipts
PK/FK job_id → outbox_jobs.id (one receipt/job)

doctor_directory_revision
PK id (singleton) · generation UUID; no FK

Sources: migrations/0001–0009; database/types.ts. Logical support tables exclude audit child partitions.

Booking without double allocation

POST /v1/consultations · patientId comes from the authenticated actor, never from request input.



Database-enforced invariants

GiST excludes overlapping doctor slots using [start, end) ranges. The unique slot index covers every status except cancelled, including completed and no_show. An INSERT trigger also locks and rejects blocked slots.

Atomic outcome and evidence

Booking, audit, encrypted idempotency result and outbox commit or roll back together. Tests: 100 distinct-key attempts → one success; 100 identical retries → one consultation, one audit and one logical event.

No network side effects in SQL

No Redis or adapter calls inside booking SQL. Workers lease only committed outbox events. Booking has no payment prerequisite. Expected conflicts return 409; unexpected persistence failures roll back.

Sources: booking.service.ts; booking.repository.ts; idempotency.*; tests/integration/booking.test.ts

Security, operations & evidence

Implemented controls are separated from undeployed infrastructure and proposed production objectives.

Authentication and authorization

Registration returns a generic response; activation/password login issue MFA-only challenges, not application access. Argon2id hashes passwords. MFA requires TOTP with atomic timestep replay protection or a single-use recovery code. Only the authorized enrollment URI discloses the seed.

Ed25519/EdDSA access JWTs default to 5 minutes; verification fixes algorithm, key ID, issuer, audience, token type and lifetime. Every protected operation rechecks live role, activation, auth version and session revocation/expiry. Patient/doctor ownership and recent-MFA admin gates prevent role or object escalation.

Opaque refresh tokens rotate with hashed all-generation history; known reuse revokes the family. Encrypted identical auth retries have a short window (30 seconds default). Sensitive account changes revoke sessions. No public doctor/admin registration; setup delivery remains an audited manual operator action.

Data protection and compliance

AES-256-GCM with record/purpose-bound AAD encrypts MFA secrets, clinical notes, prescription content and replay responses. Environment key maps support key IDs/versions; full rotation/recovery drills remain open. Zod validation, safe DTOs, no-store responses, parameterized SQL and redacted errors/logs limit disclosure.

SQL guards freeze completed notes and finalized prescription contents; corrections create linked versions. Clinical reads and privileged actions are audited atomically. Monthly audit partitions have append-only runtime controls and a fallback; function-only maintenance creates future partitions and removes expired security records after a 7-day grace. Audit/clinical deletion and legal retention are not automated.

Verified evidence; explicit limits

219 tests recorded (72 unit / 147 integration); hosted Backend CI and infrastructure/security checks passed for 9f09a95. Coverage includes concurrency, replay, access denial, rollback and worker crash recovery.

Local sample: 1,000 historical consultations, 50 writes and 200 reads; p95 14.42 ms reads / 19.87 ms writes, zero errors. This is not sustained capacity or production ingress proof. The recorded image scan retains 56 HIGH / 1 CRITICAL vendor-unfixed findings; the automated gate rejects fixable HIGH/CRITICAL only.

Scalability and reliability

PostgreSQL owns slot truth. Indexed doctor/time/status lookups, trigram name search, bounded pagination, UTC timestamps and bounded connection/query deadlines constrain work. Discovery caches public doctor fields for 30 seconds with a SQL generation check; time-filtered availability bypasses cache. Cache errors fall back to SQL; security rate limiting fails closed. Further partitioning and aggregate caches await measurement.

Workers use SKIP LOCKED leases, owner/attempt/expiry fencing and durable receipts. Retries use exponential backoff with jitter, a 60-second cap and an 8-attempt default; terminal failures are visible. Fake refunds use stable keys outside transactions. Cancellation uses doctor → slot → consultation lock order. Only future scheduled visits can be cancelled; rebooking requires a prior cancellation.

Operations and delivery

Non-root, read-only API/worker containers expose liveness/readiness and drain on shutdown. Worker credentials cannot read clinical notes/prescriptions/users/audit history and include no auth keys. Owner migrations use checksum validation, an advisory lock and one transaction/version.

Allowlisted HTTP, Kysely and consumer spans propagate traceparent through the outbox. Metrics, redacted trace-correlated logs, Prometheus/Tempo/Grafana and nine local alerts are verified. Raw SQL, bodies, credentials and clinical content are excluded from telemetry.

Terraform defines two-AZ private services, 2 API/2 worker tasks, API scaling 2–10, encrypted RDS/cache and secret references. Manual main-only OIDC deployment is defined: scan → migrate → roll → smoke; failure restores old task images, not schema. AWS delivery, paging and failover remain unverified.

Backup and disaster recovery

RDS 14-day automated backups, final snapshots and cache 7-day snapshots are defined, not deployed. An isolated logical restore verified counts and reapplied runtime grants; PITR, regional copies and key recovery were not tested. Recover to a new private DB, restore grants/keys, validate integrity and reconcile sessions/outbox before cutover. Redis is rebuilt, never used to recover bookings.

PROPOSED, NOT ACHIEVED: 100k consultations/day; p95 <200 ms reads / <500 ms writes; 99.95% availability. PITR RPO/RTO 5 min / 60 min; regional copy 24 h / 4 h. Capacity, failover, retention policy and full DR/key drills require production validation. Regional DR can exceed the monthly availability budget.

Evidence: phase5-verification.md; evidence/performance-local.json; backup-dr.md; GitHub CI for 9f09a95